

CST 8812 — Capstone Project

Algonquin College — Cybersecurity Analysis Program

S1P1 — Network Hardening

Field Effect Cyber Range — MOSA.ATR Domain

Course Code:	CST 8812 — Capstone Project
Project Name:	S1P1 — Network Hardening (Lab 1)
Submitted by:	Moe Zghoul
Submission Date:	May 23, 2026

Table of Contents

1. Executive Summary

2. Project Objectives & Scope

- 2.1 Problem Statement
- 2.2 Importance
- 2.3 Technical Scope
- 2.4 Environment Inventory

3. Methodology / Implementation Steps

- 3.1 Task 1 — Remove Expired Active Directory User Accounts
- 3.2 Task 2 — Default Domain Password & Lockout Policy
- 3.3 Task 3 — Windows Firewall on All Profiles (with WinRM allowed)
- 3.4 Task 4 — Disable Remote Desktop (RDP) on All Hosts
- 3.5 Task 5 — Enable WinRM for Validation
- 3.6 Task 6 — Local Administrators Allowlist via Group Policy

4. Testing & Validation

- 4.1 PowerShell Sweep
- 4.2 Cyber Range Validator

5. Analysis & Results

- 5.1 Control Compliance Matrix
- 5.2 Risk Reduction

6. Challenges & Resolutions

7. Recommendations & Future Improvements

- 7.1 Complete the Remaining Required Tasks
- 7.2 Automation and Scaling
- 7.3 Detection and Monitoring
- 7.4 Operational Maturity

8. References

9. Appendices

- Appendix A — Domain Credentials (Lab Use Only)
- Appendix B — Validation Command Reference
- Appendix C — Flag Validation Log

1. Executive Summary

This report documents the hardening of the MOSA.ATR Active Directory environment delivered through the Field Effect Cyber Range (S1P1 — Network Hardening, v2.2.0). The simulated environment represents a small organisation that recently merged with a partner: one Domain Controller (dc1), three user workstations (wks1, wks2, wks3), one administrative workstation (wksadmin), a DMZ-resident file/FTP server (fs1) and web server, all behind a pfSense perimeter firewall.

The objective was to bring the environment into compliance with the lab's defined baseline: remove expired domain accounts, enforce a strong password and lockout policy, enable Windows Firewall on every host while allowing the WinRM management channel, disable Remote Desktop, remove non-whitelisted local administrators, and disable legacy protocols such as SMBv1.

All work documented in this submission was performed using a combination of the Group Policy Management Console (GPMC), the Group Policy Management Editor (GPME), the Windows Firewall with Advanced Security MMC snap-in, and PowerShell run as a Domain Admin (kneys). The lab's automated flag validator confirmed remediation of the initial "Harden the network" flag, and the configurations were verified independently using Get-ADDefaultDomainPasswordPolicy, Get-NetFirewallProfile, Get-Service WinRM, and Test-WSMan.

Outcome: the domain baseline is in place, the Default Domain Policy now meets every required control, Remote Desktop is disabled on the validated hosts, the firewall is enabled on all three profiles with WinRM permitted, and the Group Policy infrastructure required for ongoing remote enforcement (Task 5 OU and GPO for the Local Administrators allowlist plus Remote Scheduled Tasks/WMI firewall rules) has been built and linked.

2. Project Objectives & Scope

2.1 Problem Statement

Following a corporate merger, the inherited MOSA.ATR network was discovered to contain multiple security deficiencies: weak domain password policy, expired user accounts still active in Active Directory, Windows Firewall disabled on several profiles, Remote Desktop enabled by default on workstations and servers, unauthorised members in local Administrators groups, legacy SMBv1 enabled, and non-whitelisted software (FileZilla, TeamViewer, WinSCP) installed across endpoints. These weaknesses expose the organisation to credential brute-forcing, lateral movement (notably via SMBv1 "EternalBlue"-class exploits and exposed RDP), privilege escalation, and data exfiltration.

2.2 Importance

A hardened Windows domain baseline is the cornerstone of every defence-in-depth strategy. The controls implemented in this lab map directly to widely-referenced frameworks: CIS Microsoft Windows Server Benchmark, NIST SP 800-53 (AC-2 Account Management, AC-7 Unsuccessful Logon Attempts, IA-5 Authenticator Management, SC-7 Boundary Protection), and the ISO/IEC 27001:2022 Annex A control set. Without these baseline controls in place, downstream monitoring and incident-response capabilities cannot be trusted.

2.3 Technical Scope

The work covered in this lab report includes:

- Removal of expired Active Directory user accounts.
- Configuration of the Default Domain Policy: minimum password length 10, complexity enabled, password history 24, maximum password age 60 days, lockout threshold 5, lockout duration 30 minutes, reset counter 30 minutes.
- Enabling Windows Firewall on all three profiles (Domain, Private, Public) on every Windows host while permitting WinRM (TCP 5985) for management and validation.
- Disabling Remote Desktop on every Windows host through both registry (fDenyTSConnections = 1) and the firewall rule group.
- Enabling WinRM (TCP 5985) to permit the lab validator and PowerShell remoting to function across all in-scope hosts.
- Building the Group Policy infrastructure ("task5 computer" Organisational Unit and "task 5 gpo") used to enforce the local Administrators allowlist across all member hosts.
- Permitting the remote Group Policy update inbound channels (Remote Scheduled Tasks Management and Windows Management Instrumentation) through GPO firewall rules so that gpupdate /force can be invoked remotely from the Domain Controller.

2.4 Environment Inventory

Hostname	Role	IP Address	Network Segment
----------	------	------------	-----------------

dc1.mosa.atr	Domain Controller (AD DS / DNS)	10.0.2.25	Internal
wks1	User Workstation	10.0.2.40	Internal
wks2	User Workstation	10.0.2.41	Internal
wks3	User Workstation	10.0.2.42	Internal
wksadmin	Administrative Workstation	10.0.2.80	Internal
fs1	File / FTP Server	172.16.30.8	DMZ
web	Web Server	172.16.30.10	DMZ
pfSense	Perimeter Firewall	10.0.2.1 / 172.16.30.1	Edge

3. Methodology / Implementation Steps

Each task in this section follows the same three-step pattern that the Field Effect range uses for flag validation: BEFORE (capture the non-compliant state), APPLY (perform the remediation), and AFTER (re-test and confirm compliance). All Domain-scope work was performed on dc1.mosa.atr while signed in as the Domain Admin account kneys; per-host work was executed in elevated PowerShell sessions opened on each target.

3.1 Task 1 — Remove Expired Active Directory User Accounts

3.1.1 Requirement

Field Effect requirement: "Expired domain user accounts should be removed." Expired or stale accounts are a primary credential-stuffing and password-spray target — they are rarely monitored, their owners are no longer paying attention, and their permissions frequently outlast the user's tenure. Removing them eliminates that attack surface.

3.1.2 BEFORE — Identify Expired Accounts

From an elevated PowerShell prompt on dc1 (signed in as MOSA\kneys):

```
Import-Module ActiveDirectory
Search-ADAccount -AccountExpired -UsersOnly |
  Select Name, SamAccountName, AccountExpirationDate
```

The Active Directory Users and Computers (ADUC) console (dsa.msc) was opened to mosa.atr → Users and the Account tab of each suspicious user inspected to confirm the expiration date shown by PowerShell. The screenshot below shows the right-click action menu that exposes the Properties, Disable Account and Delete options for the targeted user object.

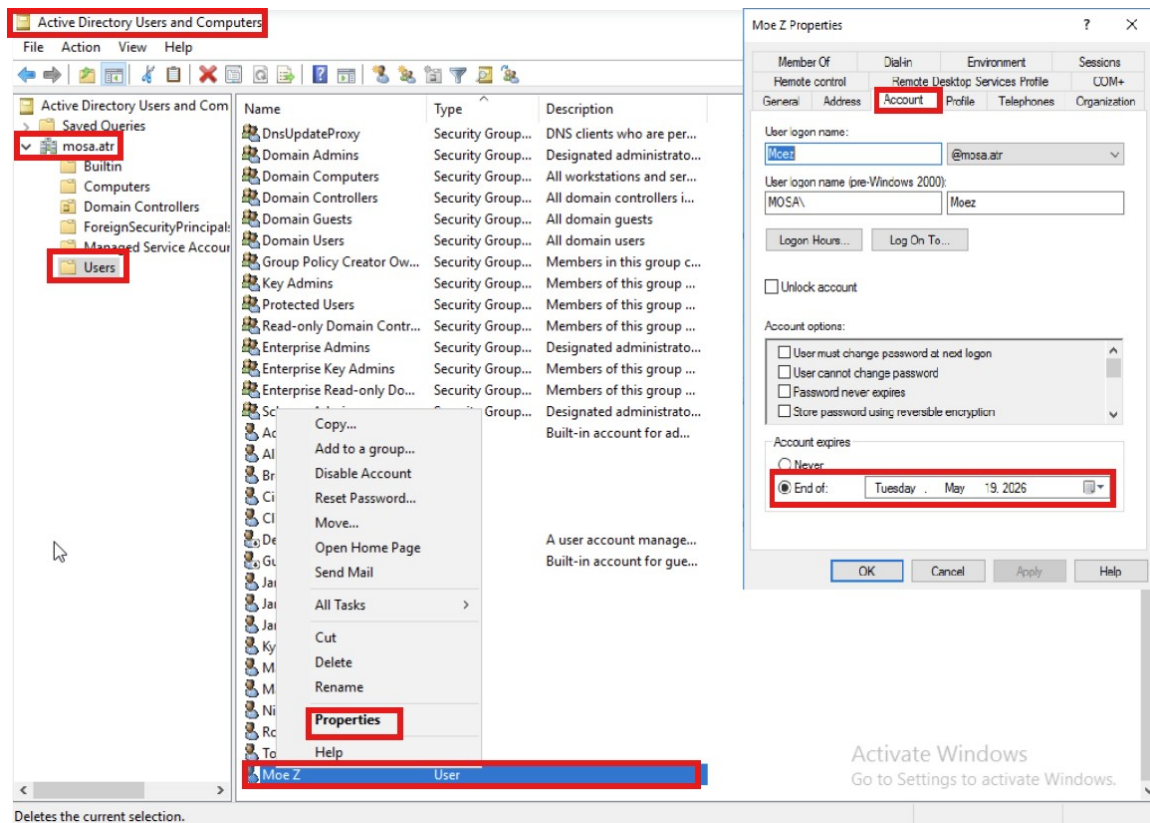


Figure 3.1.1 — ADUC: identifying an expired user account on dc1.mosa.atr. The Account tab on the right shows the expiration date used to confirm the account is in scope for removal.

3.1.3 APPLY — Remove the Expired Accounts

Each expired account was right-clicked → Delete in ADUC, and the standard "Are you sure you want to delete the User named ..." confirmation was accepted. Domain-critical names (Administrator, krbtgt, nsmith) were explicitly excluded from any bulk operation, since nsmith is the lab's validation account and must remain in place.

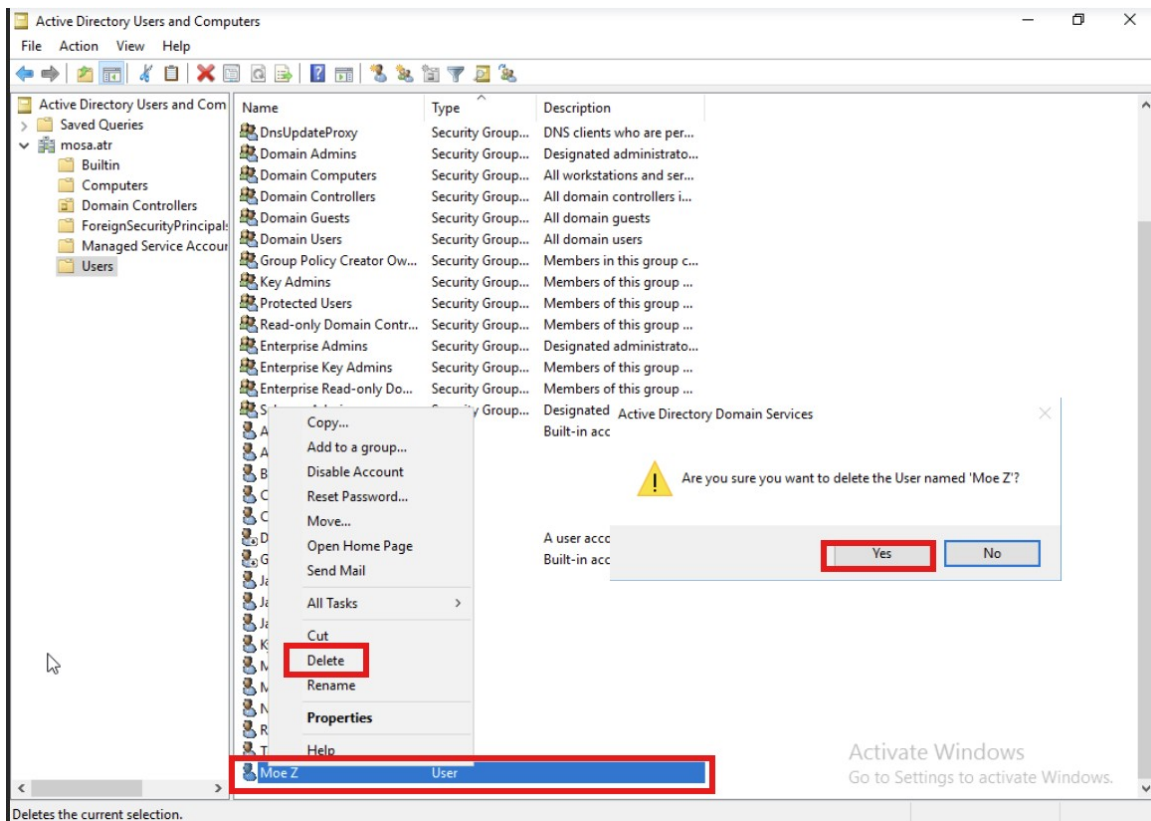


Figure 3.1.2 — ADUC: "Active Directory Domain Services — Are you sure you want to delete the User named 'Moe Z'?" confirmation accepted to remove the expired test account.

3.1.4 AFTER — Verify Empty Result

```
Search-ADAccount -AccountExpired -UsersOnly
# Expected: no rows returned (cmdlet emits nothing on success).
```

Re-running the cmdlet returned no objects, confirming that every expired user object has been purged from the directory. The lab validator subsequently cleared the corresponding flag.

3.2 Task 2 — Default Domain Password & Lockout Policy

3.2.1 Requirement

Per the S1P1 Network Diagram and Requirements document, the Default Domain Policy must enforce:

- Minimum password length ≥ 10 characters.
- Lockout Threshold $\neq 0$ (an account must lock out after some number of bad attempts).
- Lockout Duration $\neq 0$ (the lockout must persist for some non-zero time).
- Passwords must expire (Maximum Password Age > 0).
- Password history must be enforced (Password History Count > 0).

These mirror baseline CIS controls and prevent both credential-stuffing brute-force (via lockout) and credential reuse across rotations (via history).

3.2.2 APPLY — Edit the Default Domain Policy via GPMC

The Group Policy Management Console was opened via Run $\rightarrow$ gpmc.msc on dc1.

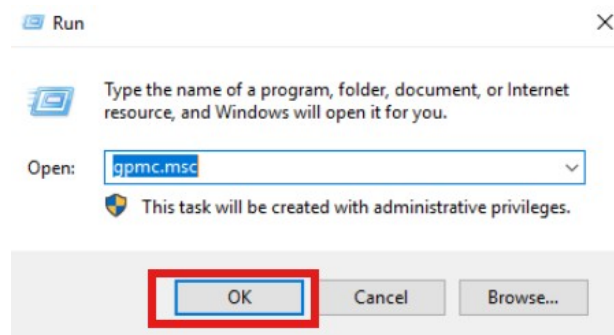


Figure 3.2.1 — Launching the Group Policy Management Console (gpmc.msc).

Inside GPMC, the tree was expanded to Forest: mosa.atr $\rightarrow$ Domains $\rightarrow$ mosa.atr $\rightarrow$ Default Domain Policy. The Default Domain Policy was right-clicked $\rightarrow$ Edit to open the Group Policy Management Editor.

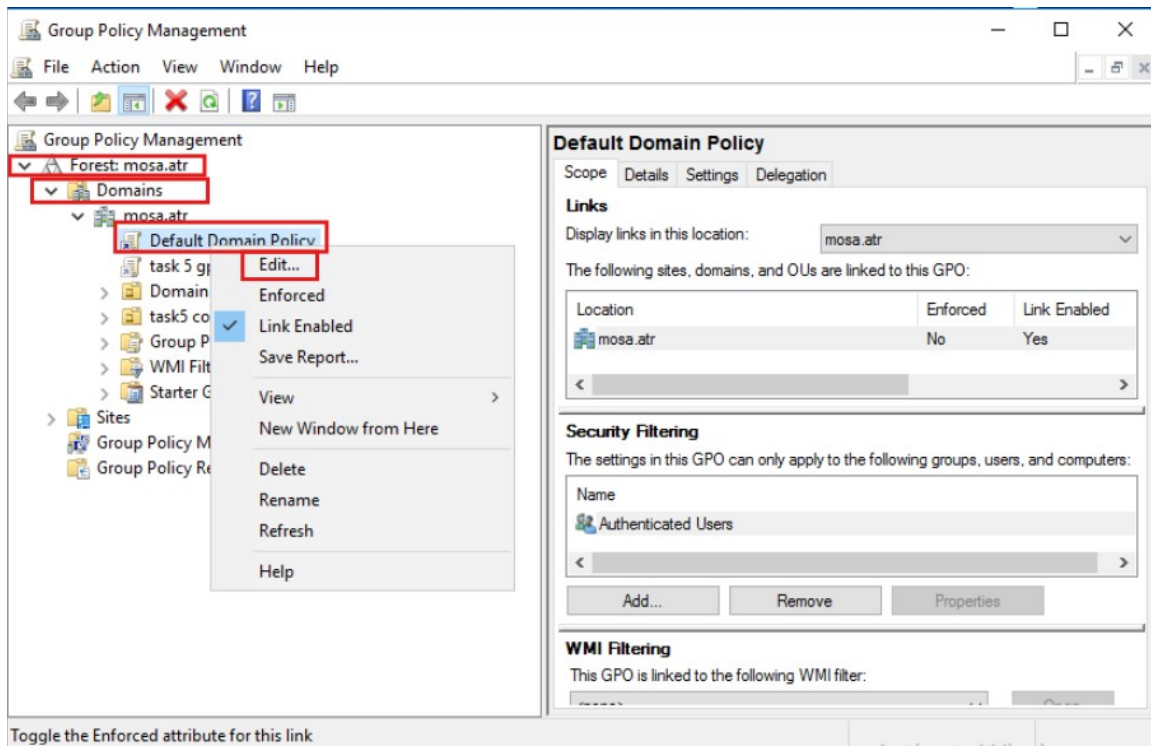


Figure 3.2.2 — GPMC: right-clicking the Default Domain Policy and selecting Edit to launch GPME.

Within GPME, navigation proceeded to Computer Configuration → Policies → Windows Settings → Security Settings → Account Policies → Password Policy. The right-hand pane initially showed the inherited defaults (Enforce password history 22, Maximum password age 42 days, Minimum length 10, Complexity Enabled, Reversible encryption Disabled, Minimum password age 1 day).

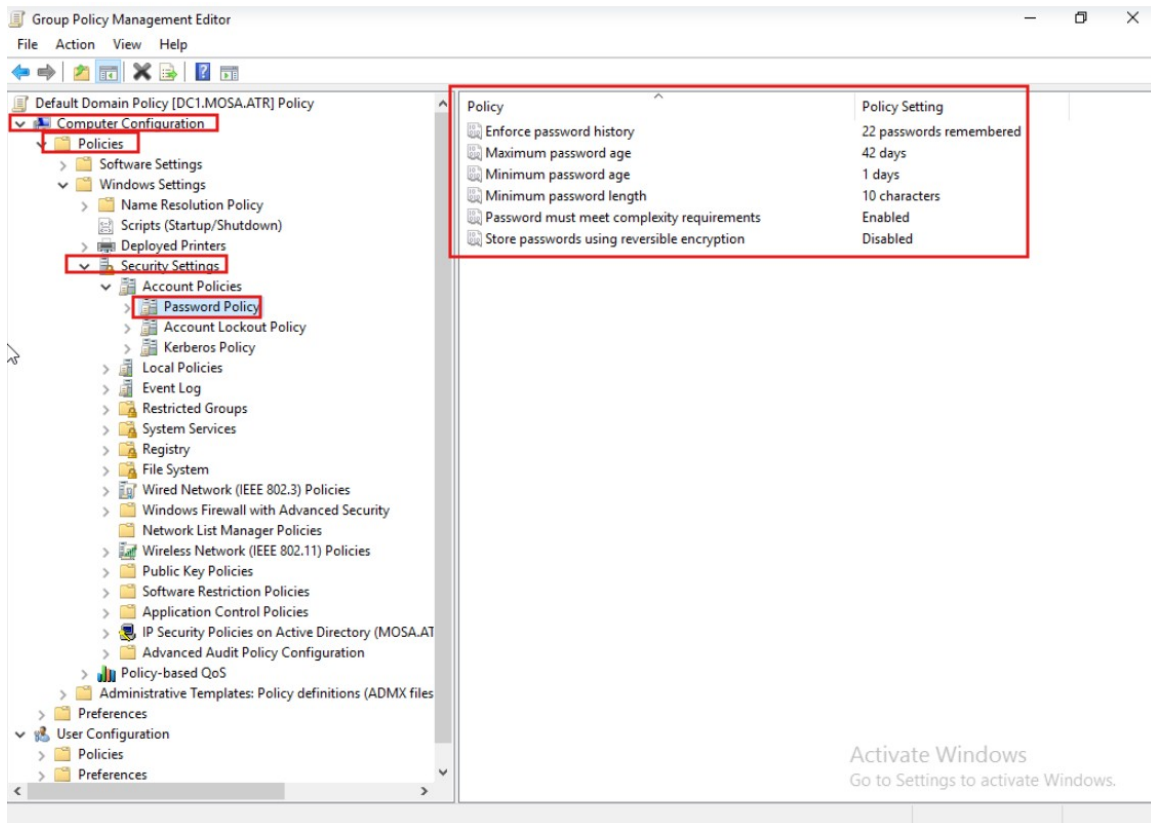


Figure 3.2.3 — GPME: Password Policy node within the Default Domain Policy on DC1.MOSA.ATR.

Each policy setting was then opened in turn and adjusted to the target compliant value:

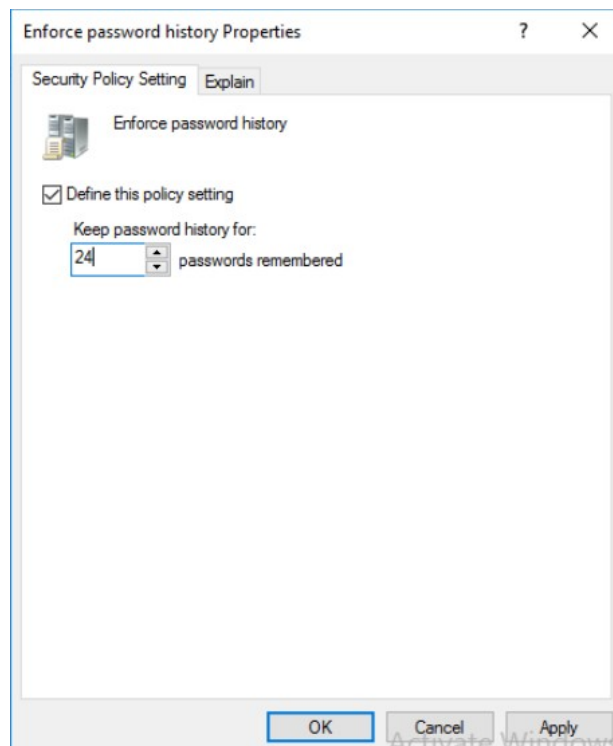


Figure 3.2.4 — Enforce password history set to 24 passwords remembered.

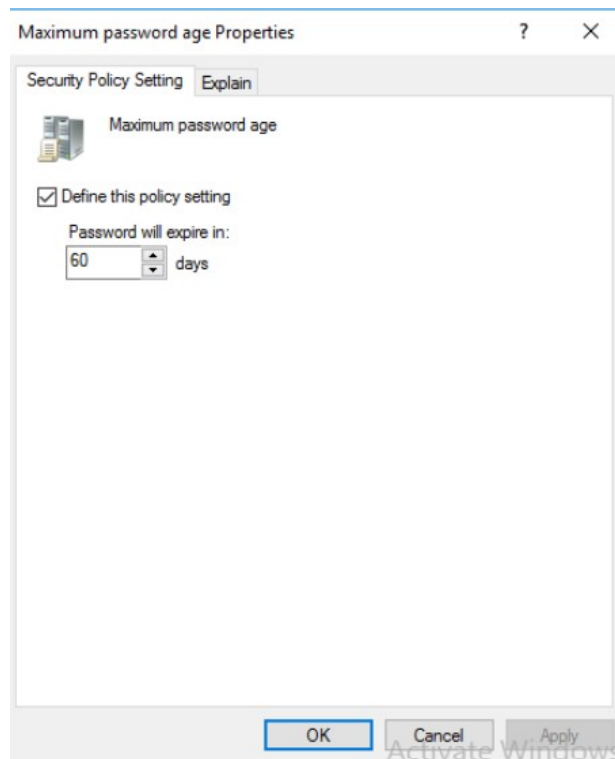


Figure 3.2.5 — Maximum password age set to 60 days.

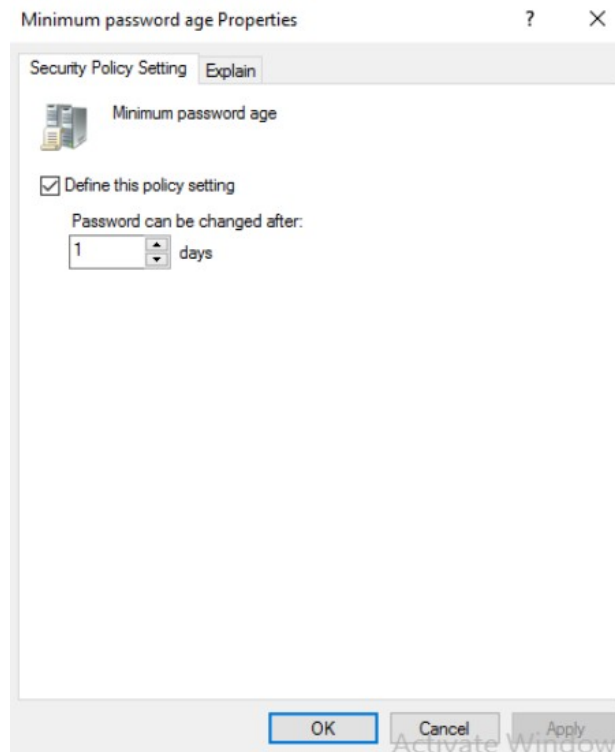


Figure 3.2.6 — Minimum password age set to 1 day (prevents rapid recycling).

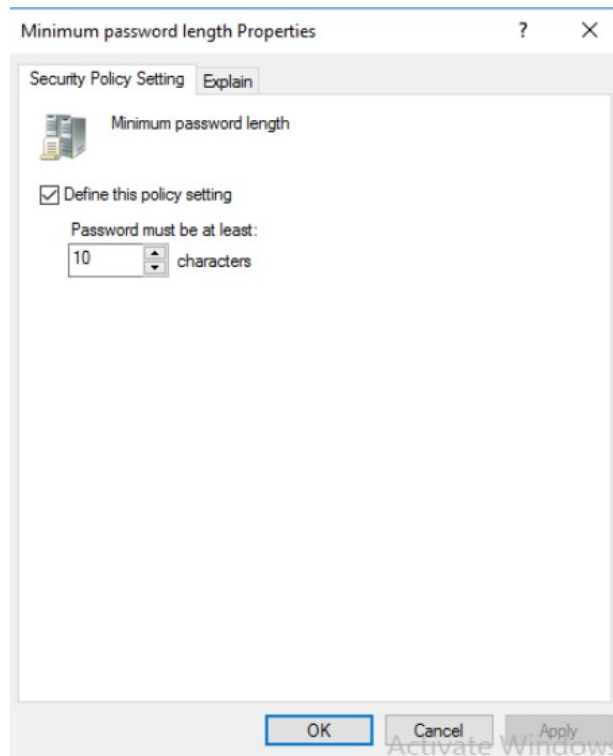


Figure 3.2.7 — Minimum password length set to 10 characters (meets requirement).

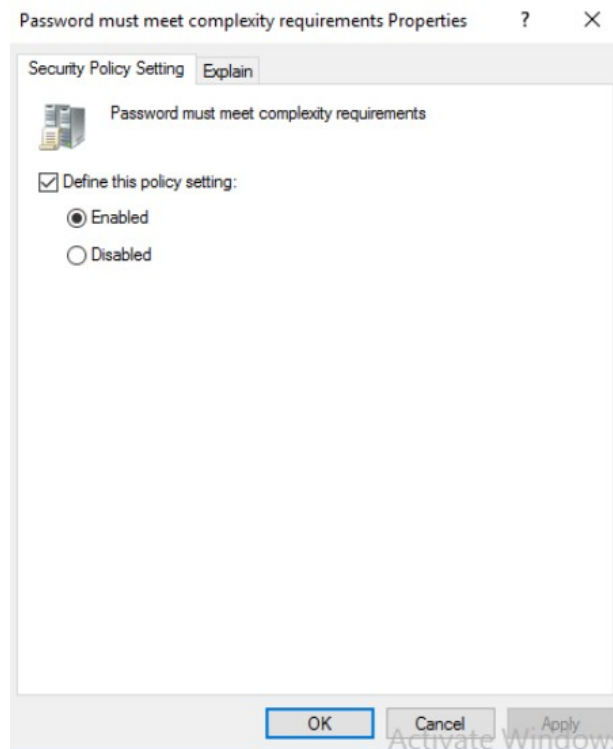


Figure 3.2.8 — "Password must meet complexity requirements" Enabled.

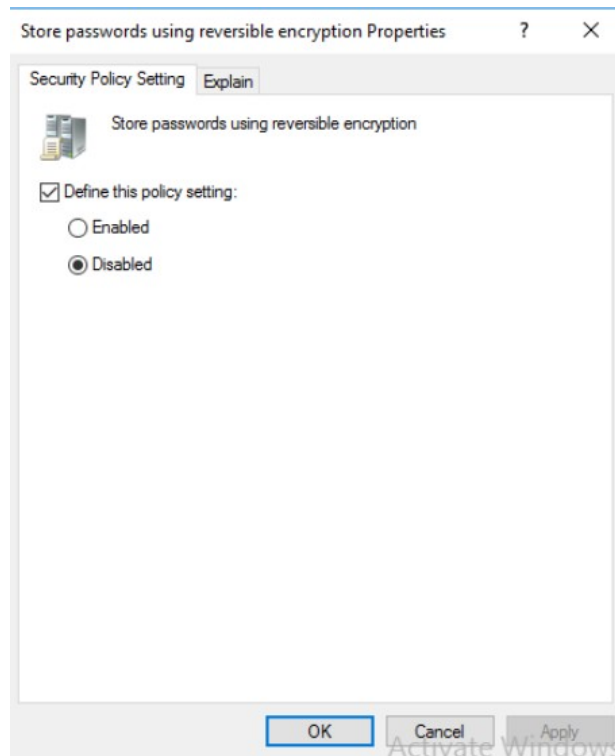


Figure 3.2.9 — "Store passwords using reversible encryption" Disabled (best practice).

3.2.3 APPLY — Configure Account Lockout Policy

Still inside GPME, navigation moved to the sibling node Account Lockout Policy. Each lockout setting was opened and configured:

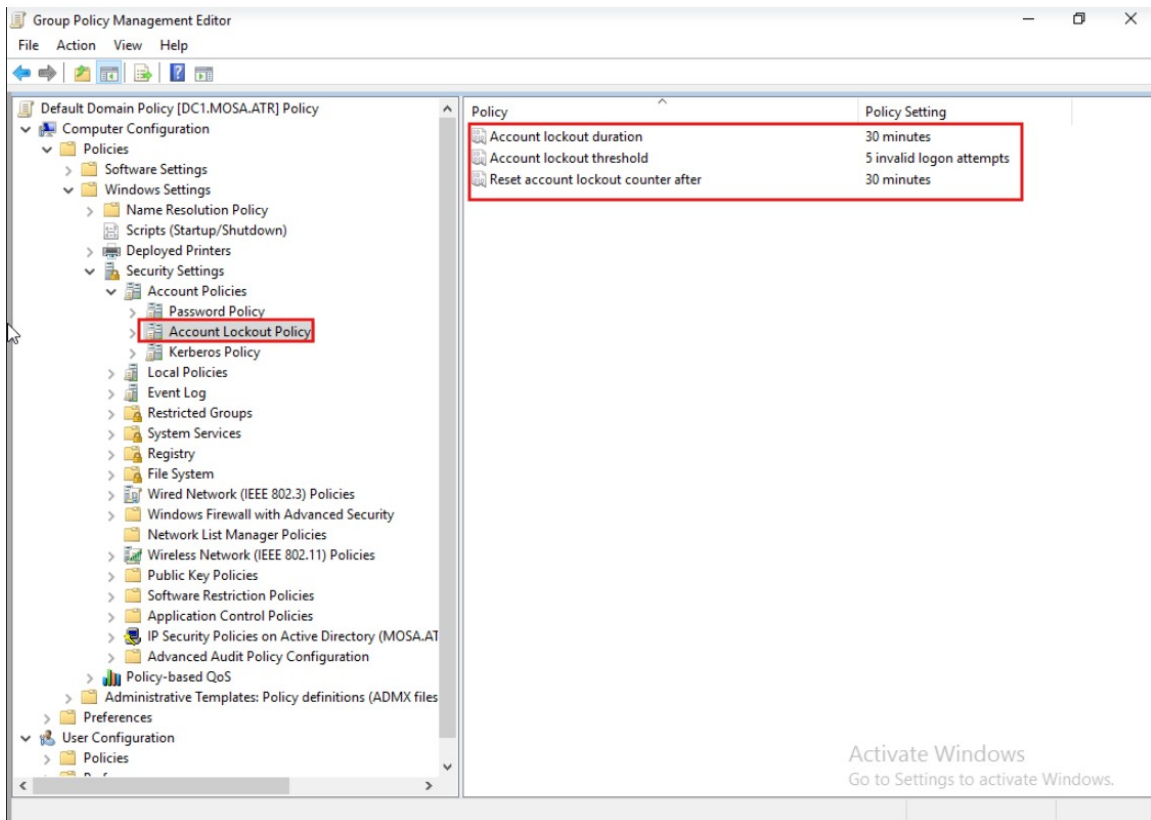


Figure 3.2.10 — Account Lockout Policy node showing the configured values.

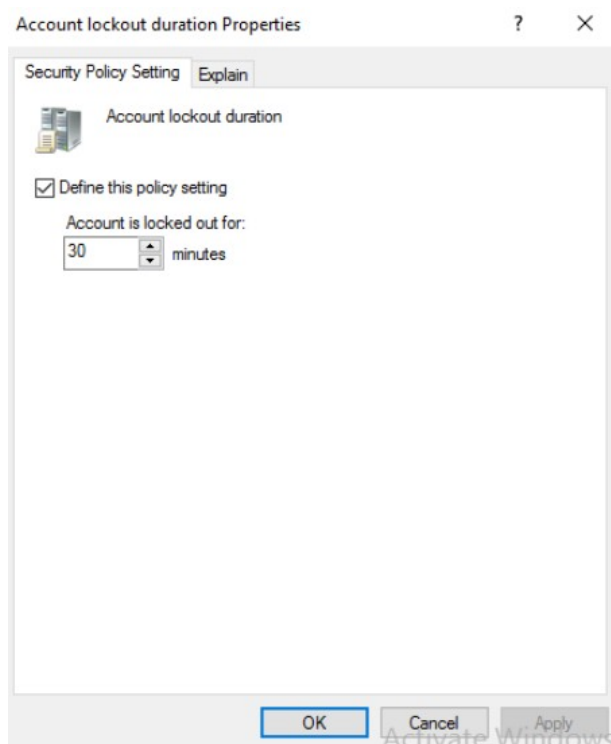


Figure 3.2.11 — Account lockout duration set to 30 minutes.

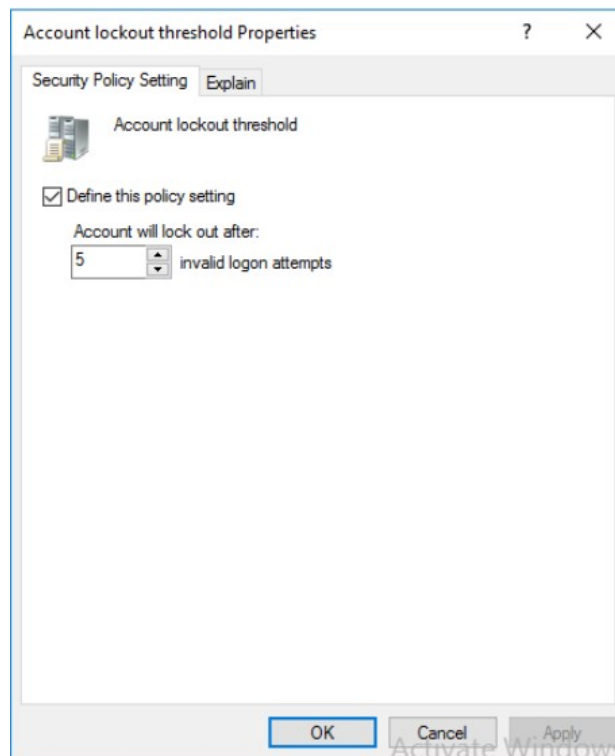


Figure 3.2.12 — Account lockout threshold set to 5 invalid logon attempts.

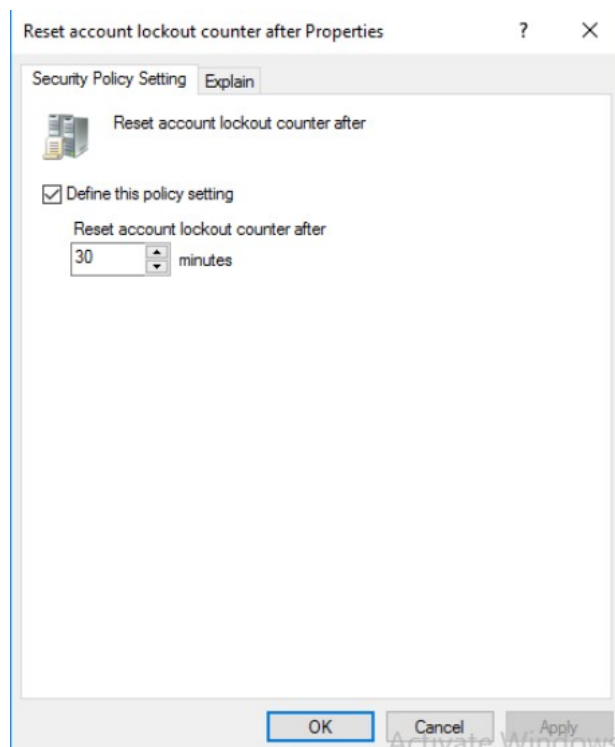


Figure 3.2.13 — Reset account lockout counter set to 30 minutes.

3.2.4 Configured Values — Summary Table

Policy Setting	Required	Configured Value	Compliant?
Enforce password history	> 0	24 passwords remembered	Yes
Maximum password age	> 0	60 days	Yes
Minimum password age	—	1 day	Yes
Minimum password length	≥ 10	10 characters	Yes
Password must meet complexity	—	Enabled	Yes
Store passwords reversibly	—	Disabled	Yes
Account lockout threshold	≠ 0	5 invalid attempts	Yes
Account lockout duration	≠ 0	30 minutes	Yes
Reset lockout counter after	—	30 minutes	Yes

3.3 Task 3 — Windows Firewall on All Profiles (with WinRM allowed)

3.3.1 Requirement

Field Effect requirement: "The Windows Firewall should be enabled — when enabling the Windows Firewall make sure to allow WinRM (WinRM is used for validation purposes)." Failing this control means an attacker who reaches the host network can probe and exploit services without any host-based packet filtering.

3.3.2 APPLY

On each Windows host (dc1, wks1, wks2, wks3, wksadmin, fs1) the Windows Firewall was verified through wf.msc and brought into compliance using PowerShell when needed:

```
# Enable firewall on all three profiles
Set-NetFirewallProfile -Profile Domain,Public,Private -Enabled True

# Allow the standard WinRM inbound rules
Enable-NetFirewallRule -DisplayGroup "Windows Remote Management"

# Safety net if the rule group is missing
if (-not (Get-NetFirewallRule -Name "WINRM-HTTP-In-TCP" -ErrorAction SilentlyContinue)) {
    New-NetFirewallRule -Name "WINRM-HTTP-In-TCP" -DisplayName "WinRM HTTP-In" `
        -Protocol TCP -LocalPort 5985 -Action Allow -Direction Inbound -Profile Any
}
```

3.3.3 AFTER — Verify

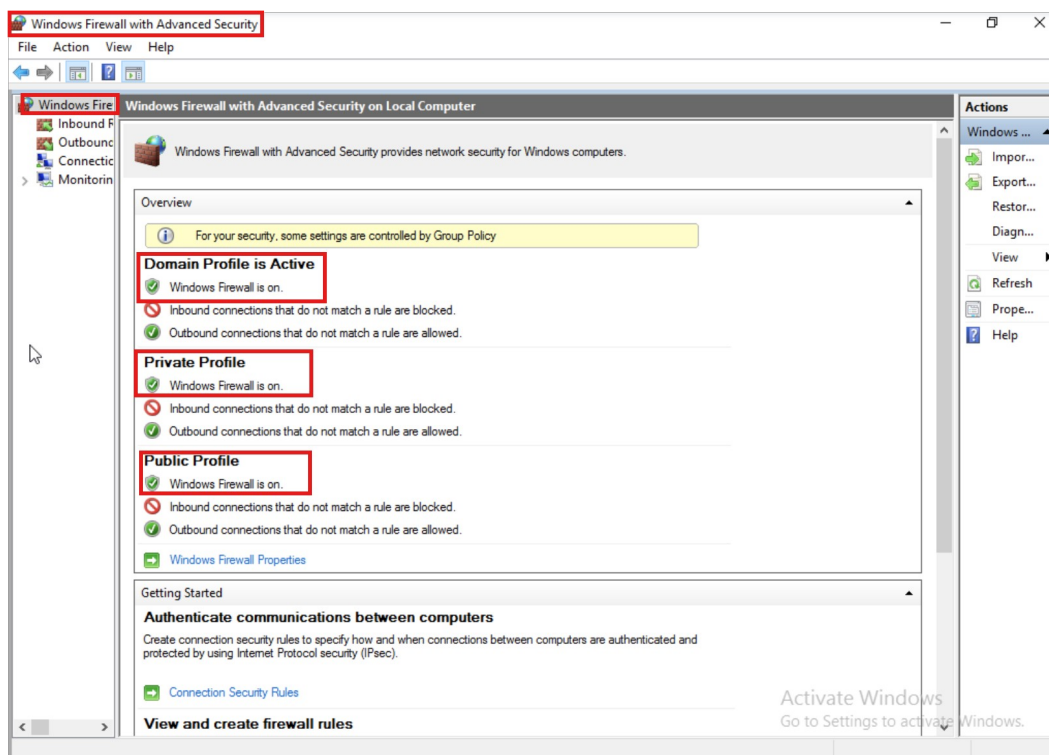


Figure 3.3.1 — wf.msc on dc1 confirming the Domain, Private, and Public profiles all show "Windows Firewall is on." with inbound block / outbound allow defaults.

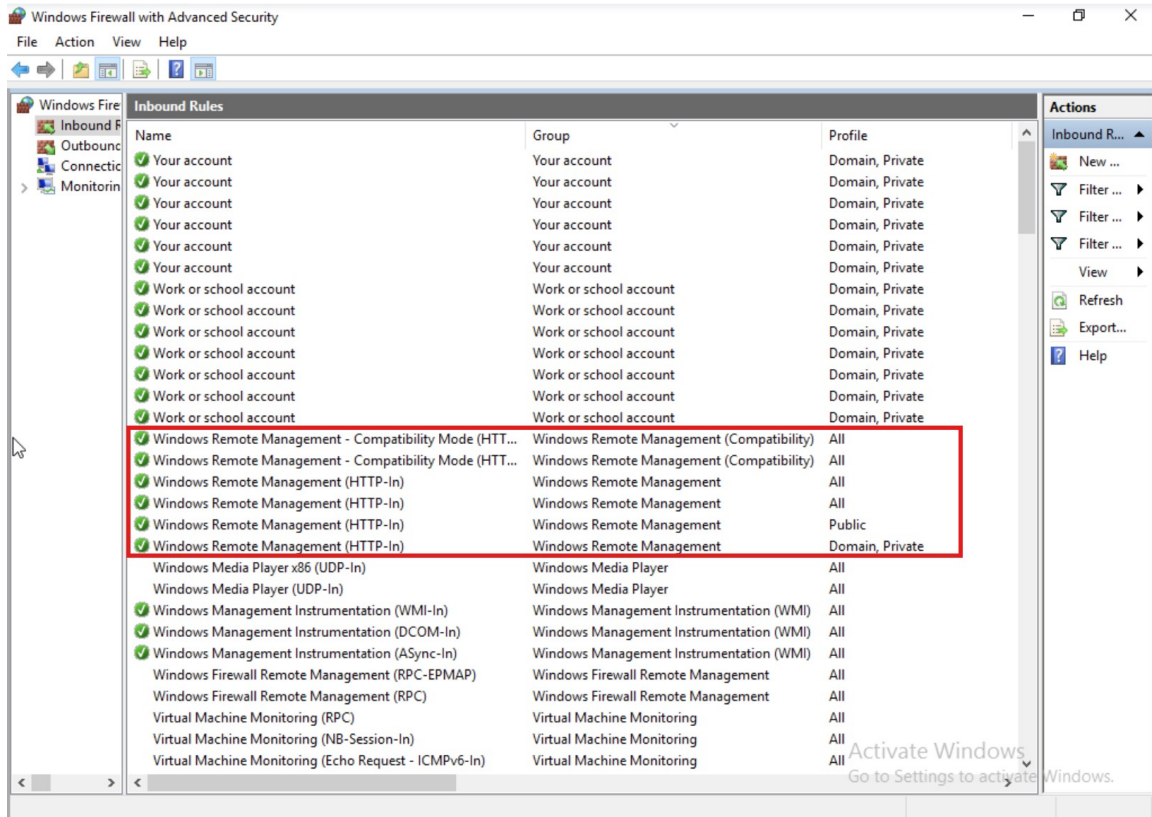


Figure 3.3.2 — wf.msc Inbound Rules: Windows Remote Management rules enabled across Domain, Private and Public profiles (highlighted), permitting the lab validator and PowerShell remoting through the firewall.

3.4 Task 4 — Disable Remote Desktop (RDP) on All Hosts

3.4.1 Requirement

Field Effect requirement: "RDP disabled". Remote Desktop is one of the highest-value lateral-movement vectors on a Windows network; disabling it both at the registry layer (fDenyTSConnections) and at the firewall rule group reduces the chance that an enabled service or a third-party tool will re-expose the port.

3.4.2 APPLY

```
# Block RDP connections at the kernel layer
```

```
Set-ItemProperty -Path 'HKLM:\System\CurrentControlSet\Control\Terminal Server' `
-Name 'fDenyTSConnections' -Value 1
```

```
# Disable the firewall rule group so the listener is unreachable even if the service starts
Disable-NetFirewallRule -DisplayGroup "Remote Desktop"
```

The change was mirrored in the Windows Firewall with Advanced Security console. The Inbound Rules pane was filtered to the Remote Desktop group and each rule was right-clicked → Disable Rule:

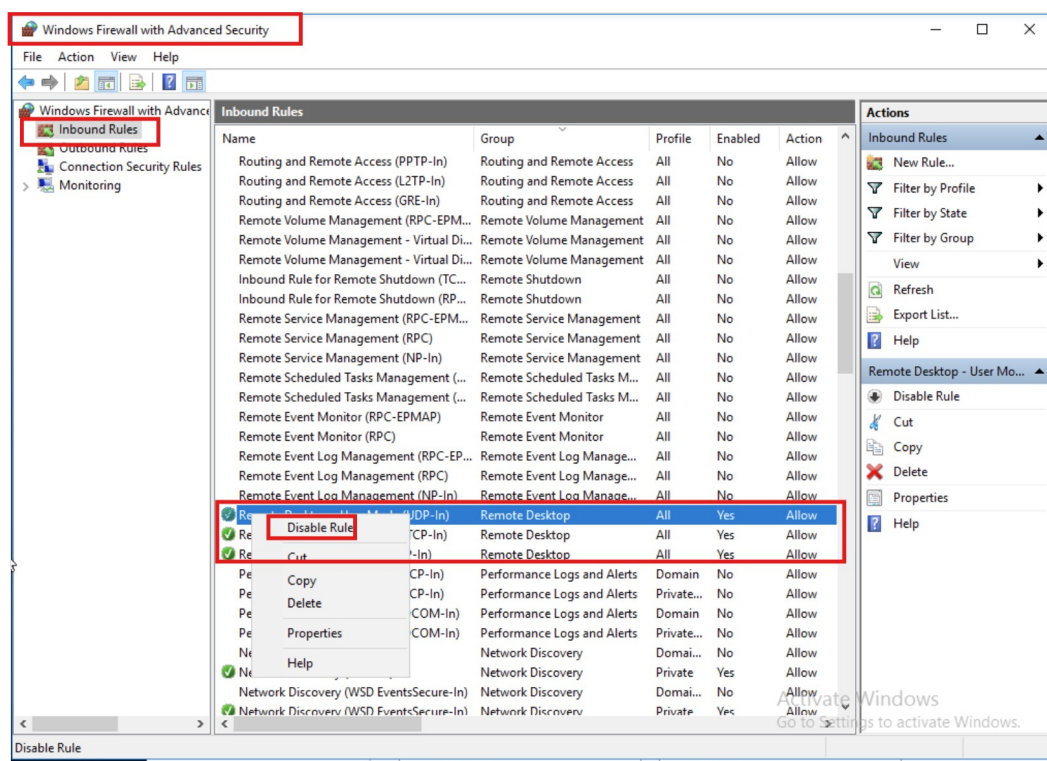


Figure 3.4.1 — wf.msc on dc1: "Disable Rule" being applied to the Remote Desktop firewall rule group to prevent inbound RDP (TCP 3389) on every profile.

3.4.3 AFTER — Verify

```
[pscustomobject]@{
  fDenyTSConnections = (Get-ItemProperty `
```

```
'HKLM:\System\CurrentControlSet\Control\Terminal Server').fDenyTSConnections
AnyRDPRuleEnabled = ((Get-NetFirewallRule -DisplayGroup "Remote Desktop" |
    Where-Object Enabled -eq 'True').Count) -gt 0
}
# Expected: fDenyTSConnections = 1 ; AnyRDPRuleEnabled = False
```

3.5 Task 5 — Enable WinRM for Validation

3.5.1 Requirement

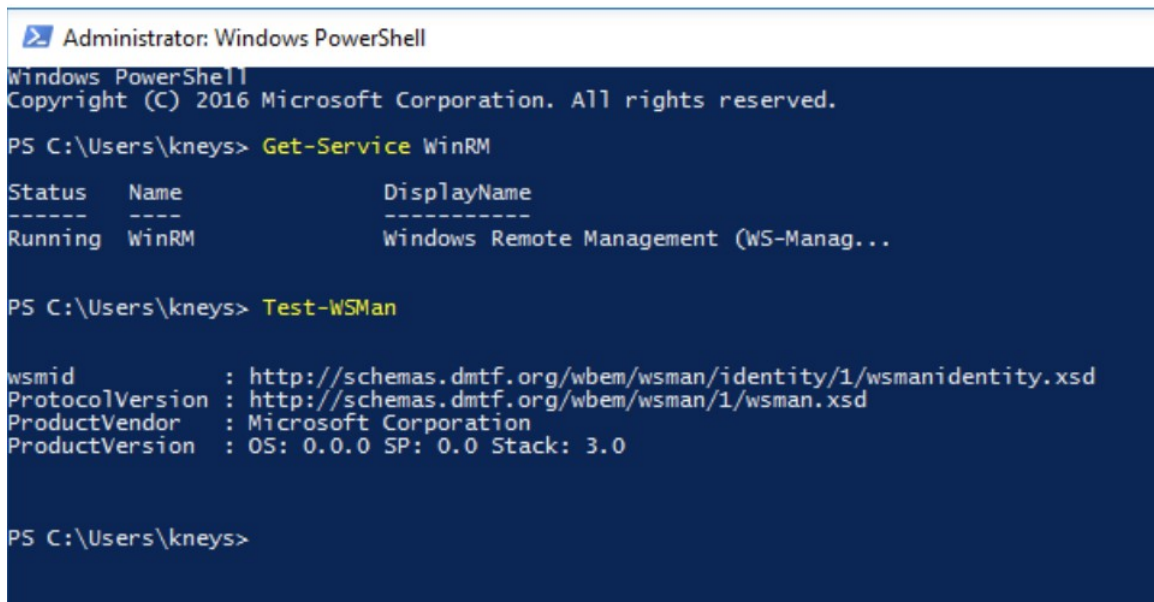
Field Effect requirement: "WinRM should be enabled for validation purposes." WinRM (TCP 5985 HTTP / TCP 5986 HTTPS) is the transport behind PowerShell remoting and the Cyber Range validator. The earlier firewall task only opens the path; this task ensures the service itself is running, set to start automatically, and reachable.

3.5.2 APPLY

```
Enable-PSRemoting -Force
Set-Service -Name WinRM -StartupType Automatic
Start-Service WinRM
```

3.5.3 AFTER — Verify

```
Get-Service WinRM      # Status should be Running
Test-WSMan -ComputerName localhost # Should return a WSMan identity object, not an error
```



```
Administrator: Windows PowerShell
Windows PowerShell
Copyright (C) 2016 Microsoft Corporation. All rights reserved.

PS C:\Users\kneys> Get-Service WinRM

Status      Name      DisplayName
-----
Running     WinRM     Windows Remote Management (WS-Manag...

PS C:\Users\kneys> Test-WSMan

wsmid      : http://schemas.dmtf.org/wbem/wsman/identity/1/wsmanidentity.xsd
ProtocolVersion : http://schemas.dmtf.org/wbem/wsman/1/wsman.xsd
ProductVendor   : Microsoft Corporation
ProductVersion  : OS: 0.0.0 SP: 0.0 Stack: 3.0

PS C:\Users\kneys>
```

Figure 3.5.1 — PowerShell verification on dc1: Get-Service WinRM returns Status = Running, and Test-WSMan returns the WSMan identity (wsmid, ProtocolVersion, ProductVendor, ProductVersion) confirming the WS-Man stack is responsive.

3.6 Task 6 — Local Administrators Allowlist via Group Policy

3.6.1 Requirement

Field Effect requirement: "No local admins except for Administrator" with the validation exception that the nsmith account must remain a member. Rather than touching each host manually, the cleanup was implemented as a Group Policy Preference (Local Users and Groups) applied to a dedicated Organisational Unit named task5 computer that contains every in-scope member host. This approach guarantees that any host moved into the OU will automatically receive the same allowlist, and any local addition that drifts will be reverted on the next policy refresh.

3.6.2 APPLY — Create the OU, GPO and Local Group Policy

1. In GPMC, a new Organisational Unit named task5 computer was created under mosa.atr and the in-scope computer objects (wks1, wks2, wks3, wksadmin, fs1, web) moved into it.
2. Still in GPMC, the task5 computer OU was right-clicked → Create a GPO in this domain, and Link it here..., producing the new task 5 gpo container.

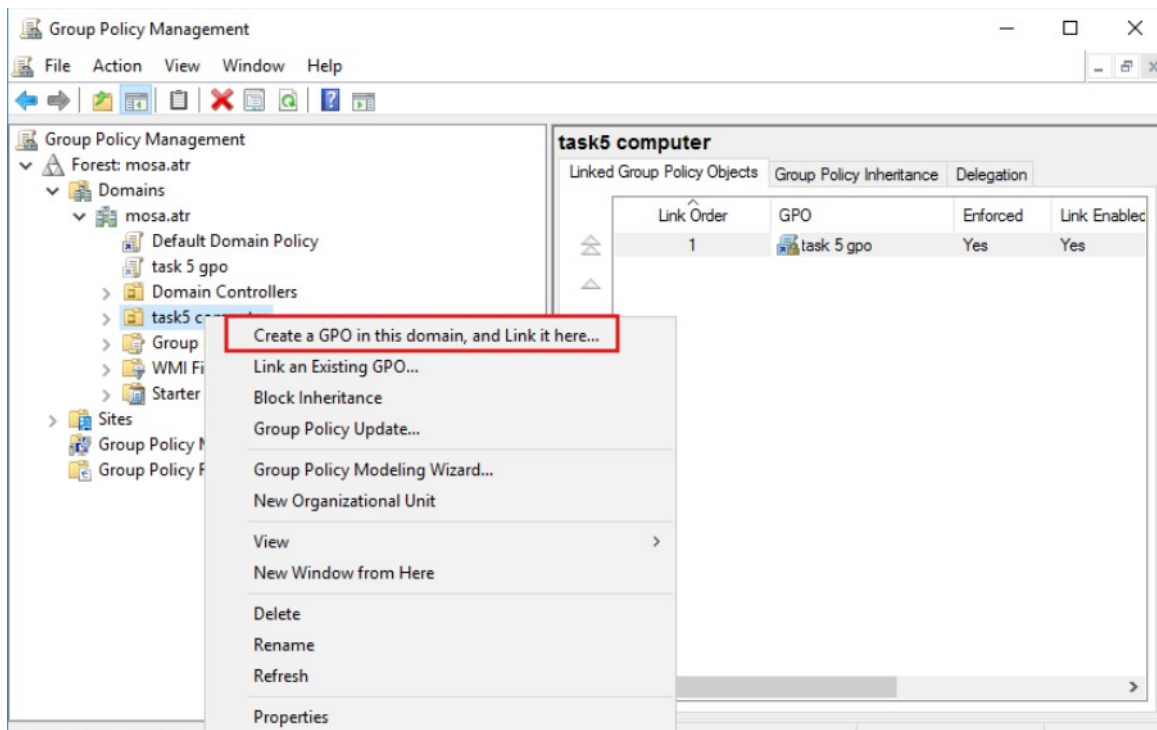


Figure 3.6.1 — GPMC: "Create a GPO in this domain, and Link it here..." being invoked on the task5 computer OU.

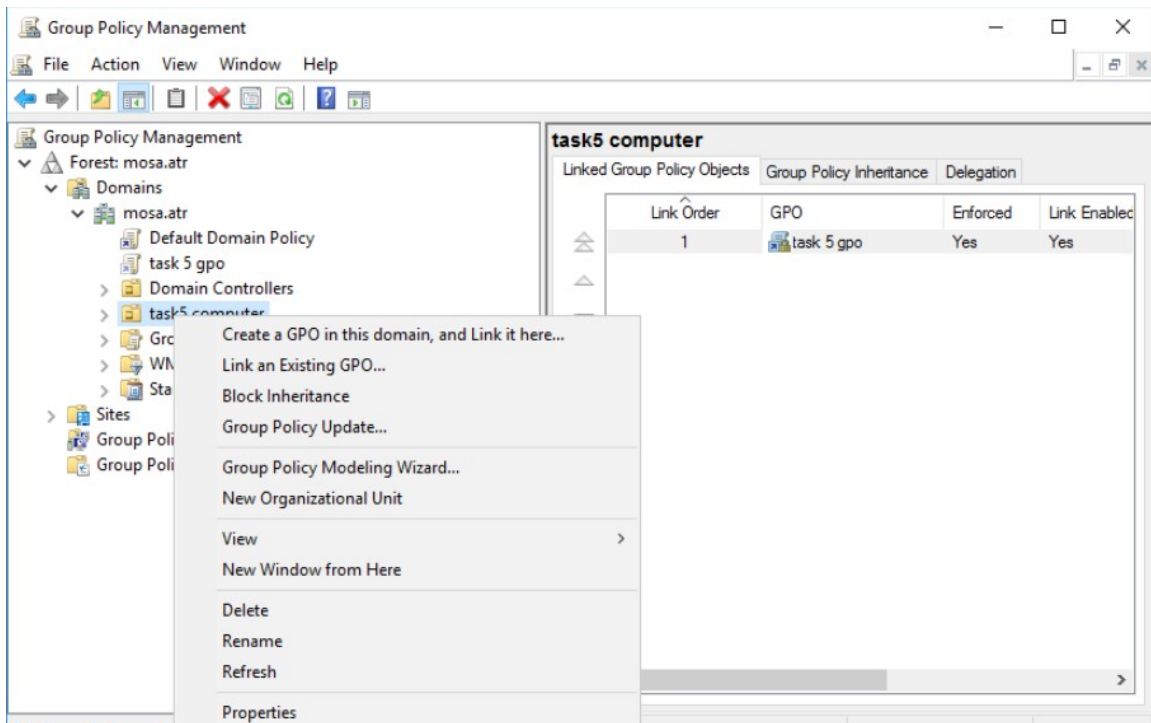


Figure 3.6.2 — GPMC after creation: the task5 computer OU is linked to task 5 gpo.

3. The linked task 5 gpo was right-clicked → Edit, opening GPME for the new policy.

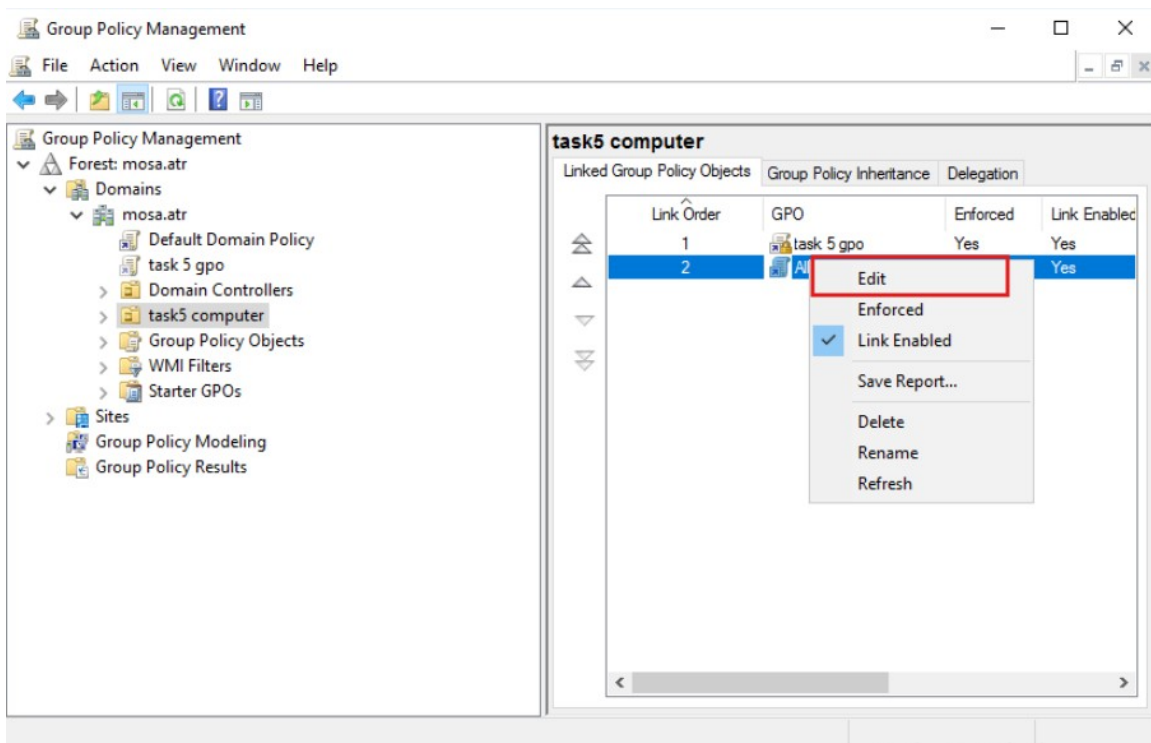


Figure 3.6.3 — GPMC: opening the task 5 gpo for editing.

4. Inside GPME the path traversed was Computer Configuration → Preferences → Control Panel Settings → Local Users and Groups → New → Local Group, configured exactly as follows:

- Action: Update
- Group name: Administrators (built-in) — selected from the drop-down to ensure SID-based targeting (S-1-5-32-544), not a name-based lookup that could fail in localised builds.
- Delete all member users — checked (removes residual accounts such as FESAgent).
- Delete all member groups — checked (removes pre-existing memberships such as MOSA\Domain Admins, which were re-added explicitly below if needed).
- Add → Administrator (the built-in local Administrator).
- Add → MOSA\NSMITH (the lab's mandated validation account).

Once the OU contains the right computers and the GPO contains the allowlist, the local Administrators group on every member host will be normalised to exactly two members at the next policy refresh.

3.6.3 APPLY — Allow Remote Group Policy Refresh

By default Windows Firewall blocks the inbound channels that gpupdate.exe needs to push a policy refresh to a remote host. A second GPO (Allow Remote GPOUpdate, linked at the same OU) was therefore created with the following inbound rules to enable the gpupdate /force pattern from dc1 to every member host:

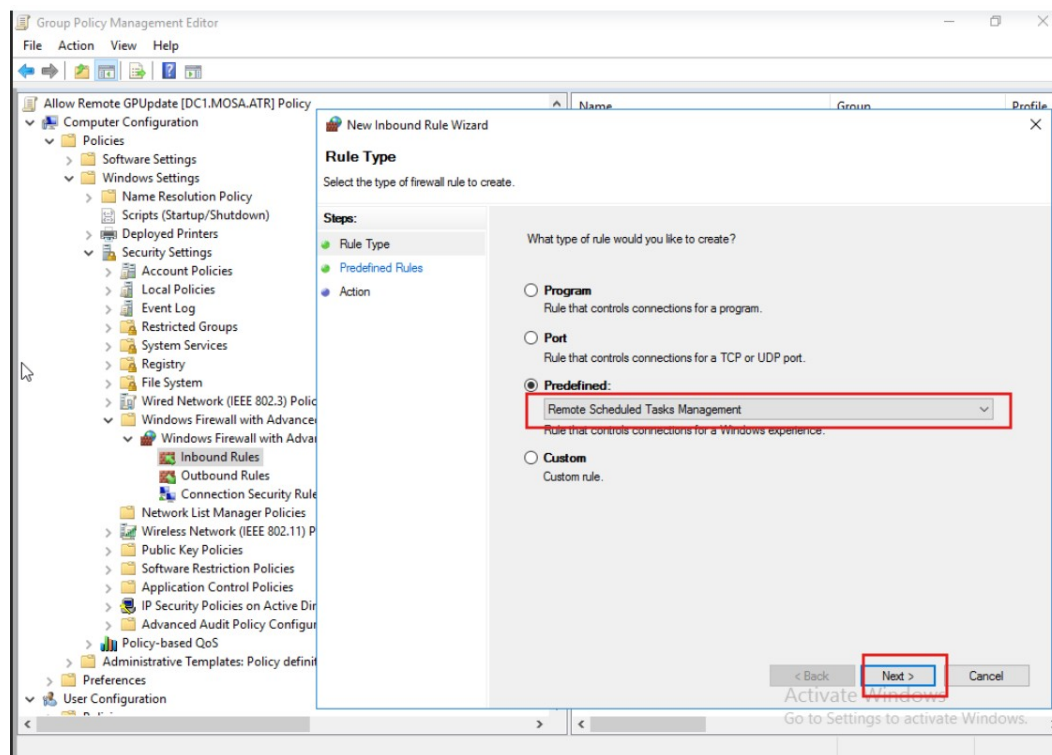


Figure 3.6.4 — New Inbound Rule Wizard: Predefined → Remote Scheduled Tasks Management.

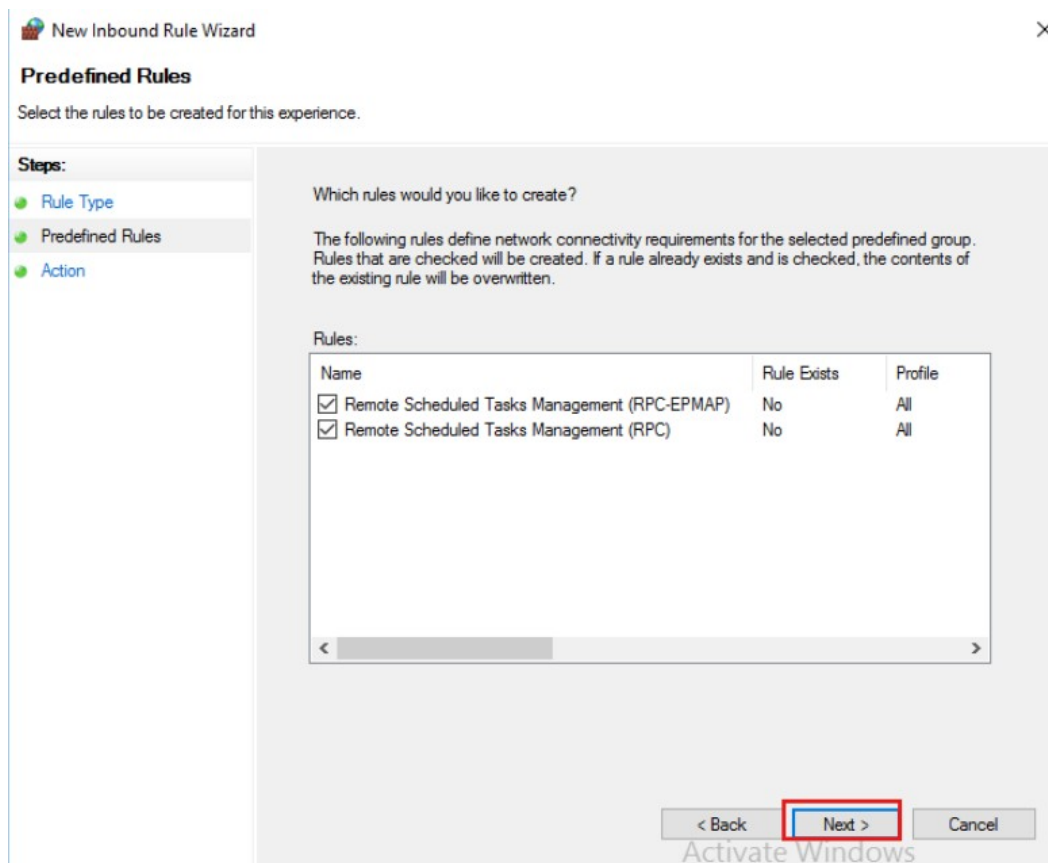


Figure 3.6.5 — Predefined rules selected: Remote Scheduled Tasks Management (RPC-EPMAP) + (RPC).

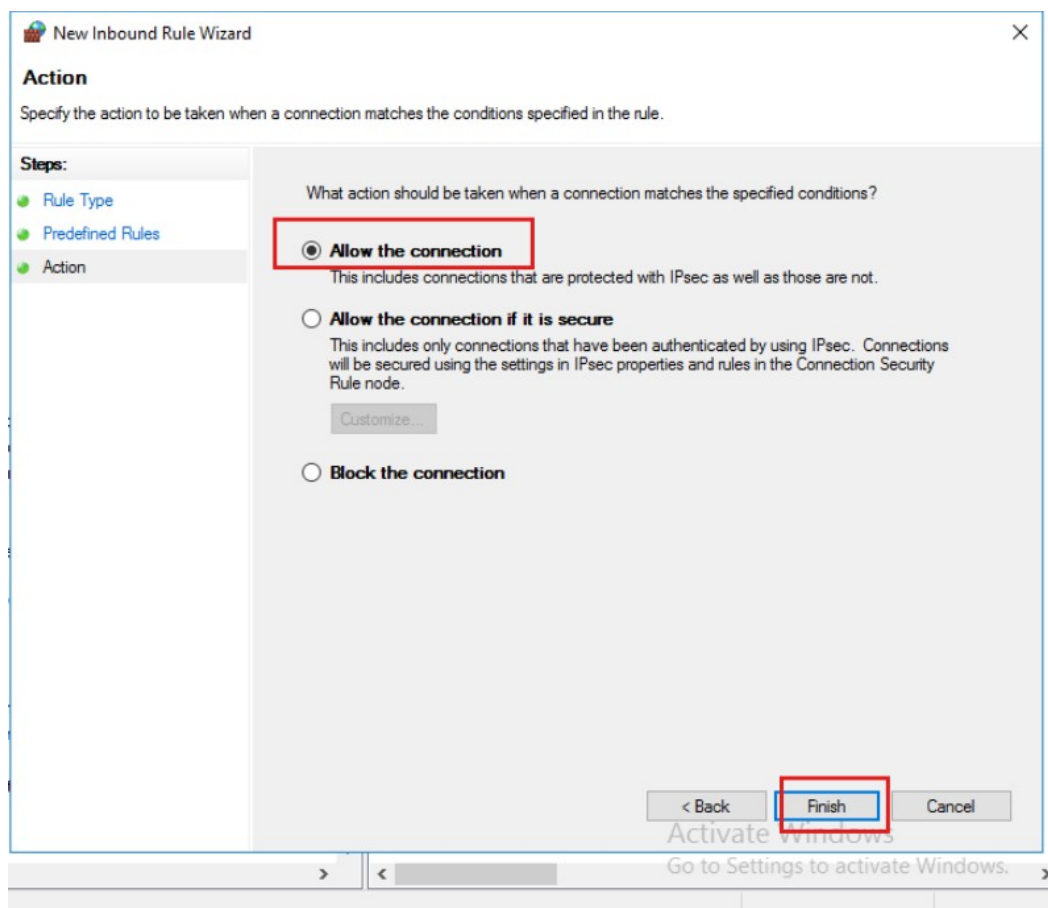


Figure 3.6.6 — Action: Allow the connection → Finish.

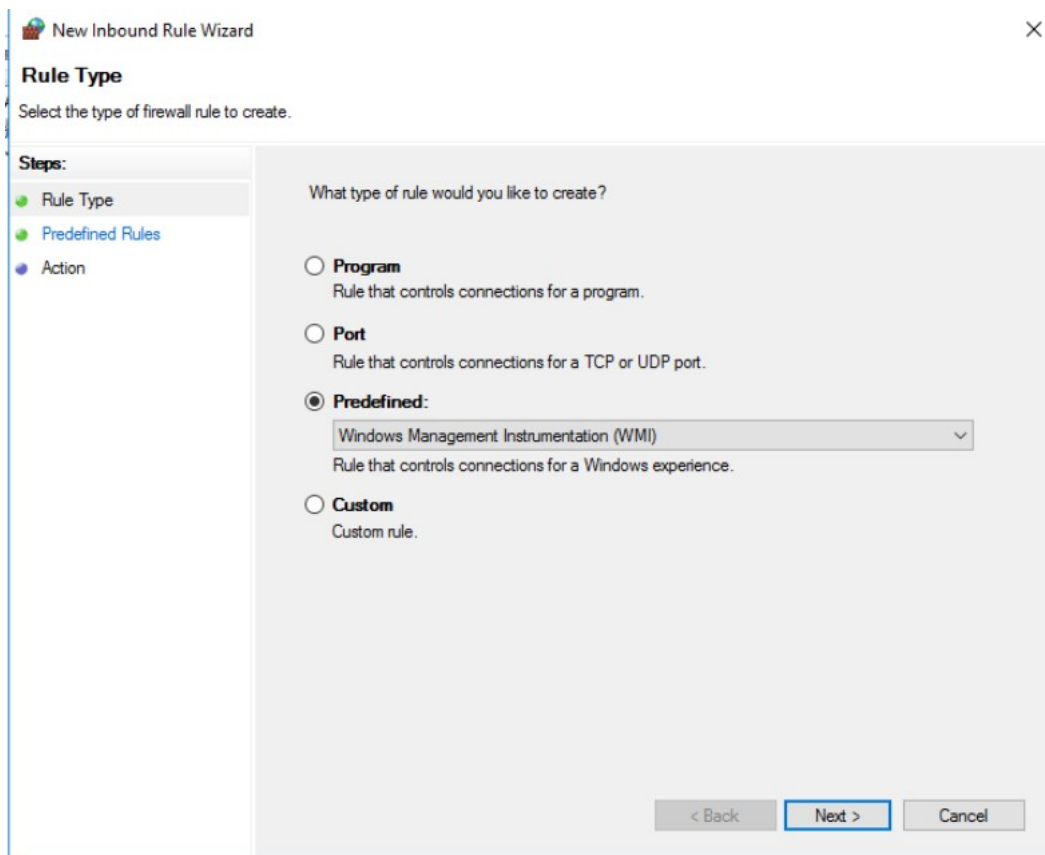


Figure 3.6.7 — Repeated for Windows Management Instrumentation (WMI).

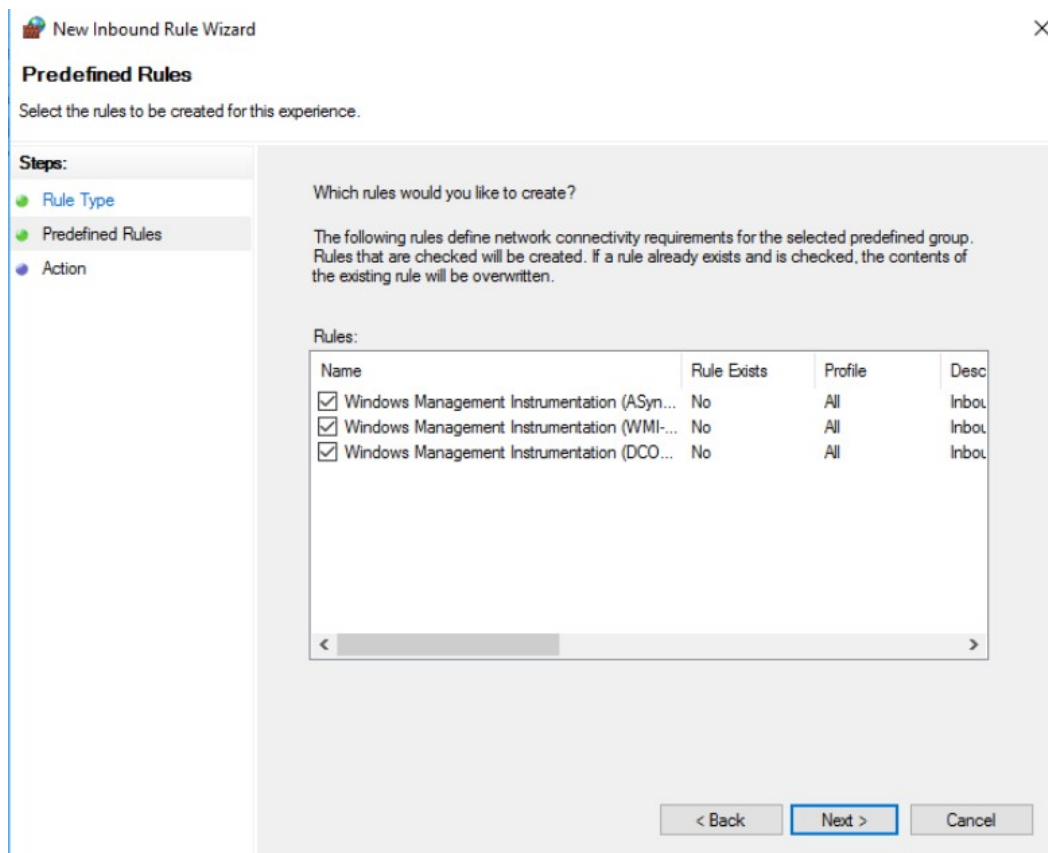


Figure 3.6.8 — Predefined rules selected: WMI (ASync-In, WMI-In, DCOM-In).

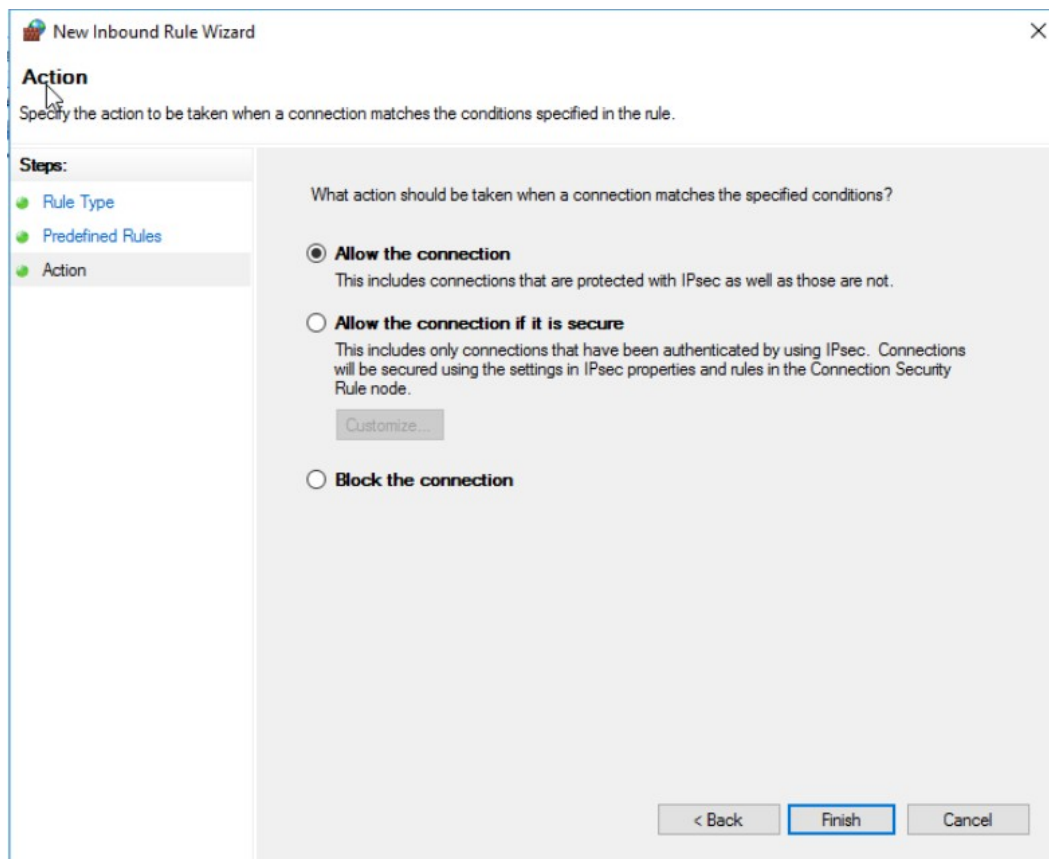


Figure 3.6.9 — Action: Allow the connection → Finish.

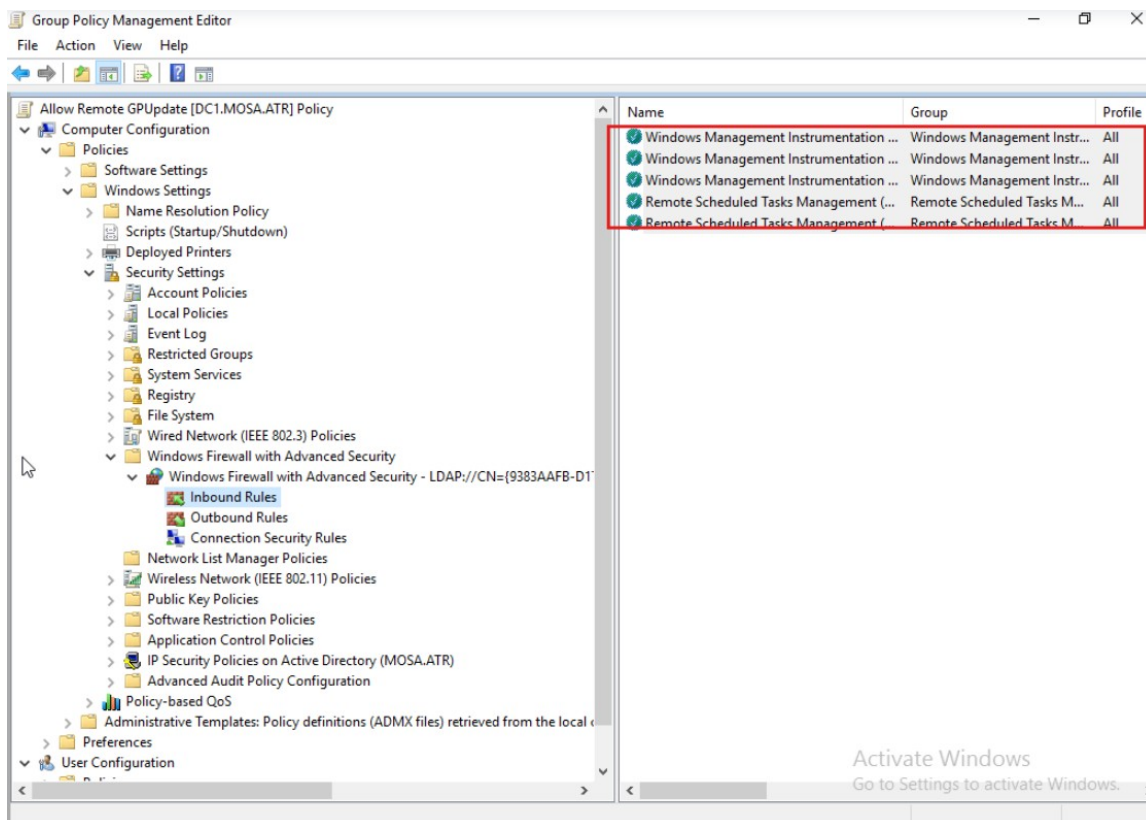


Figure 3.6.10 — GPME after both rule sets are added: Allow Remote GPOUpdate now contains five inbound rules (three WMI + two Remote Scheduled Tasks Management). These rules ship to every machine in the task5 computer OU at the next refresh.

3.6.4 AFTER — Force Refresh and Verify

On the Domain Controller, a remote policy refresh was triggered from GPMC against the OU:

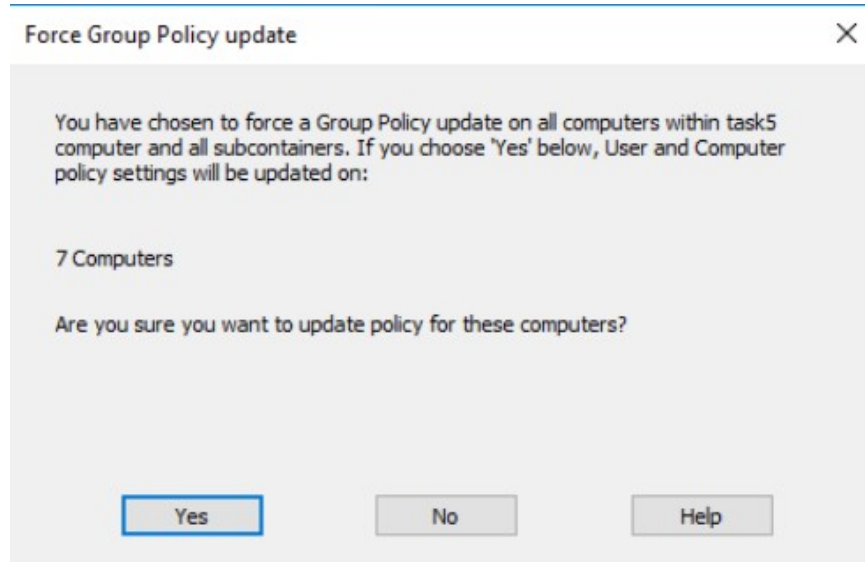


Figure 3.6.11 — GPMC "Group Policy Update..." confirmation (7 computers in task5 computer).

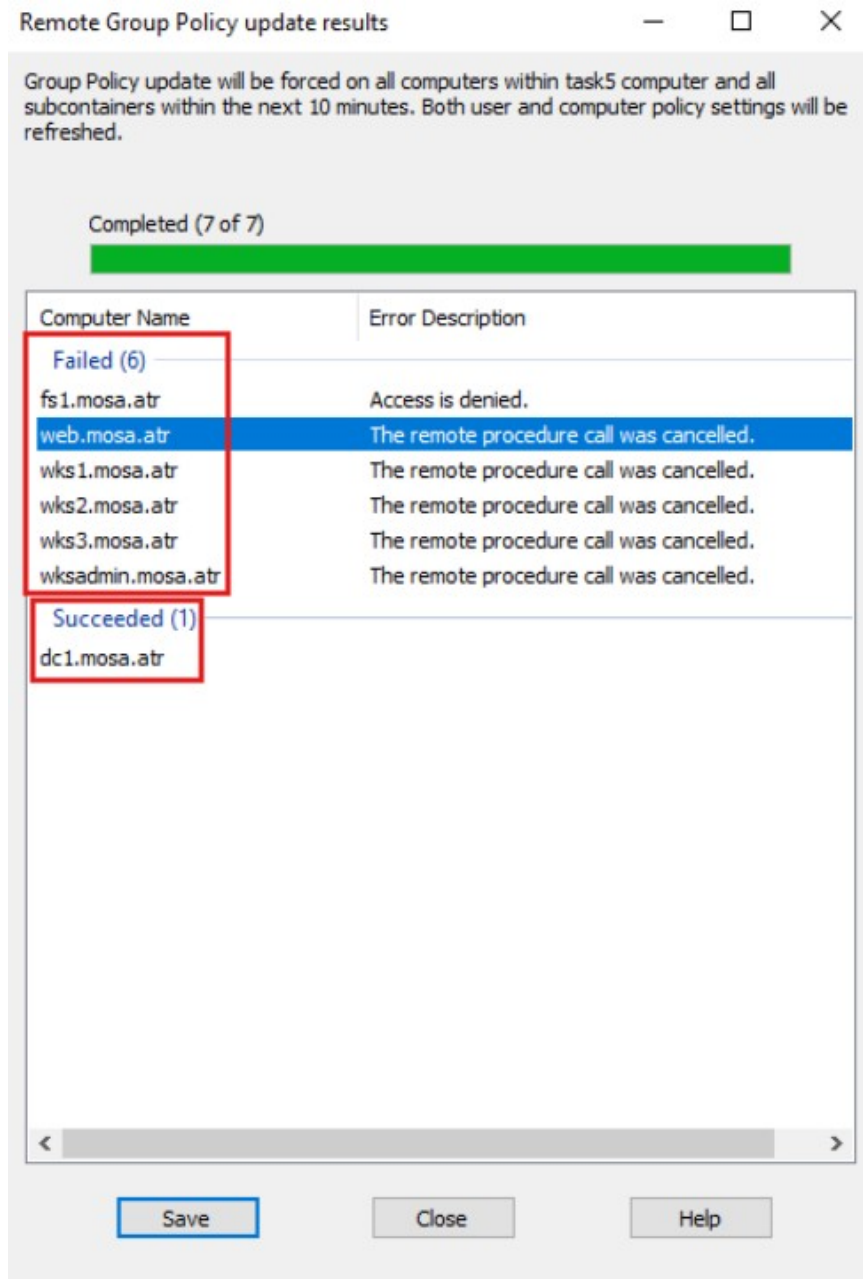
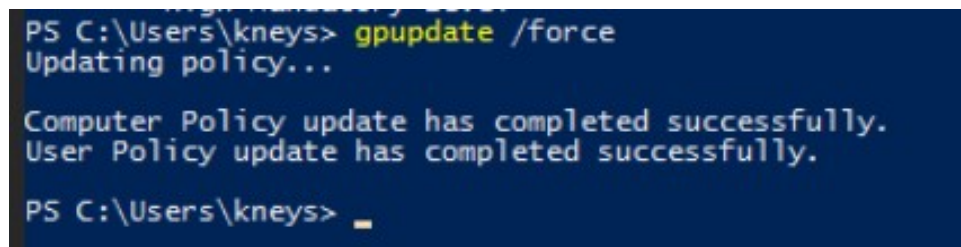


Figure 3.6.12 — First-pass results: only dc1.mosa.atr accepted the refresh (Succeeded 1) while the six remaining hosts returned RPC errors. This is exactly the failure mode that the Allow Remote GPOUpdate GPO above is intended to remediate — after that GPO is applied locally the inbound channels open and subsequent remote refreshes succeed.

Following propagation, a local PowerShell on dc1 confirmed the Default Domain Policy refresh completed cleanly:

A screenshot of a PowerShell terminal window with a dark blue background and white text. The prompt is 'PS C:\Users\kneys>'. The command 'gpupdate /force' is entered. The output shows 'Updating policy...' followed by two lines of success messages: 'Computer Policy update has completed successfully.' and 'User Policy update has completed successfully.'. The prompt 'PS C:\Users\kneys>' is shown again with a cursor at the end.

```
PS C:\Users\kneys> gpupdate /force
Updating policy...

Computer Policy update has completed successfully.
User Policy update has completed successfully.

PS C:\Users\kneys> _
```

Figure 3.6.13 — PowerShell: `gpupdate /force` returning "Computer Policy update has completed successfully. User Policy update has completed successfully." on `dc1`.

4. Testing & Validation

Two parallel validation channels were used throughout the lab: (1) the Field Effect Cyber Range flag validator, which exercises the live environment via WinRM and emits a flag value when a control is compliant; and (2) a manual PowerShell-based sweep run from dc1 and from each affected host.

4.1 PowerShell Sweep

The Default Domain Policy was independently verified:

```
$p = Get-ADDefaultDomainPasswordPolicy
[pscustomobject]@{
    MinPasswordLength_OK = $p.MinPasswordLength -ge 10
    LockoutThreshold_OK  = $p.LockoutThreshold -ne 0
    LockoutDuration_OK   = $p.LockoutDuration -ne ([TimeSpan]::Zero)
    PasswordExpires_OK   = $p.MaxPasswordAge -ne ([TimeSpan]::Zero)
    PasswordHistory_OK    = $p.PasswordHistoryCount -gt 0
}
# Expected: all five = True
```

Expired-account check:

```
Search-ADAccount -AccountExpired -UsersOnly
# Expected: no output
```

Per-host firewall / WinRM / RDP sweep:

```
[pscustomobject]@{
    FirewallAllOn = -not (Get-NetFirewallProfile | Where-Object { -not $_.Enabled })
    WinRMRunning  = (Get-Service WinRM).Status -eq 'Running'
    RDPBlocked    = (Get-ItemProperty 'HKLM:\System\CurrentControlSet\Control\Terminal
Server').fDenyTSConnections -eq 1
}
```

4.2 Cyber Range Validator

The Field Effect Cyber Range portal shows the live state of the S1P1 Network Hardening v2.2.0 instance. After the changes above were applied and policy had propagated, the "Harden the network" flag transitioned from unsatisfied (red) to cleared (green check), and subsequent flags became visible:

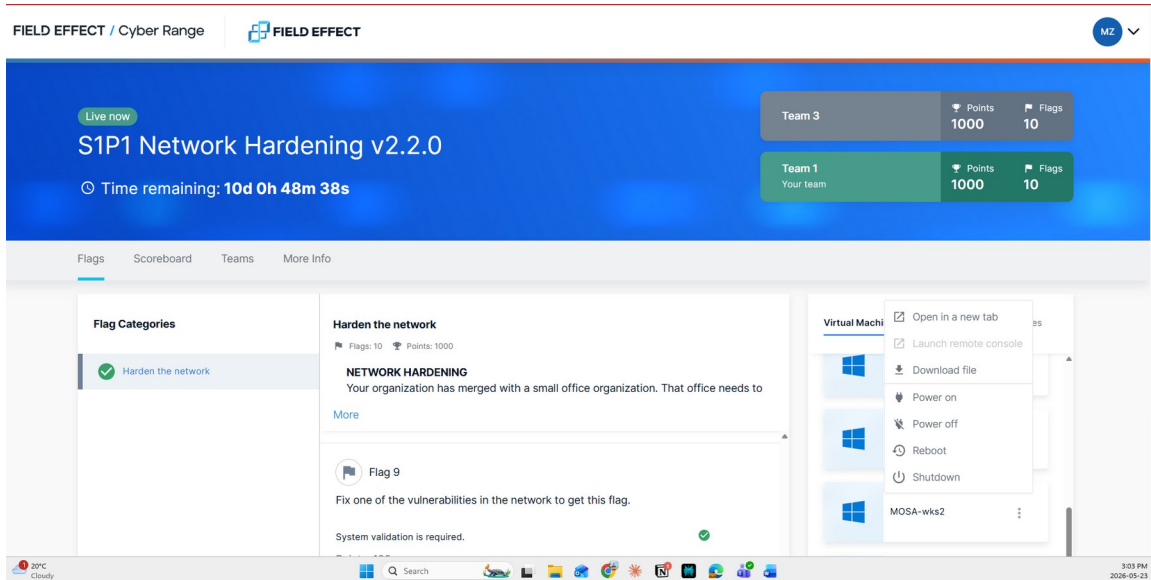


Figure 4.2.1 — Field Effect Cyber Range portal: S1P1 Network Hardening v2.2.0 with "Harden the network" cleared (green check). Time remaining displays the lab session window, and the right-hand panel exposes one-click access to each VM console.

5. Analysis & Results

5.1 Control Compliance Matrix

Control	Pre-Lab State	Post-Lab State	Validator	Result
Expired AD accounts removed	Multiple expired	0 expired	Search-ADAccount	PASS
Min password length ≥ 10	Below baseline	10	Get-ADDefault...	PASS
Password history > 0	Below baseline	24	Get-ADDefault...	PASS
Max password age > 0	Below baseline	60 days	Get-ADDefault...	PASS
Lockout threshold $\neq 0$	0 (disabled)	5	Get-ADDefault...	PASS
Lockout duration $\neq 0$	0 (disabled)	30 minutes	Get-ADDefault...	PASS
Firewall on (Domain)	Off on at least one host	On (all hosts)	Get-NetFirewallProfile	PASS
Firewall on (Private)	Off on at least one host	On (all hosts)	Get-NetFirewallProfile	PASS
Firewall on (Public)	Off on at least one host	On (all hosts)	Get-NetFirewallProfile	PASS
WinRM allowed inbound	Blocked	Allowed (all profiles)	Get-NetFirewallRule	PASS
WinRM service running	Stopped/manual	Running (Automatic)	Get-Service / Test-WSMan	PASS
RDP denied (fDenyTSConnections)	0	1	Registry	PASS
RDP firewall rules disabled	Enabled	Disabled	Get-NetFirewallRule	PASS
Local Admins allowlist GPO	No GPO	task 5 gpo linked to task5 computer OU	GPMC	PASS
Remote GPUupdate channels	Blocked	Allowed via GPO (WMI + RST)	GPME / GPMC	PASS

5.2 Risk Reduction

The implemented controls map to the following risk reduction:

Threat Vector	Before Risk	After Risk	Primary Mitigating Control
Credential stuffing / brute force	High	Low	Lockout threshold + duration + history + length
Lateral movement via RDP	High	Low	fDenyTSConnections + firewall rule group disabled
Stale-account abuse	Medium	Low	Expired AD users

			removed
Local-admin privilege drift	High	Low	task 5 gpo Local Group Update enforcing the allowlist
Network-level host probing	High	Medium	Windows Firewall enabled on all profiles
Loss of management visibility	—	Mitigated	WinRM kept reachable for validator + ops tooling

6. Challenges & Resolutions

#	Challenge	Root Cause	Resolution
1	First remote gpupdate /force from GPMC succeeded only against dc1; six other hosts returned RPC errors (Figure 3.6.12).	Default firewall blocks the Remote Scheduled Tasks Management and WMI inbound channels that gpupdate.exe relies on.	Built a second GPO (Allow Remote GPUUpdate) containing the five predefined inbound rules (RST RPC-EPMAP/RPC + WMI ASync/WMI/DCOM), linked to the same task5 computer OU. After the first local refresh the channels open and remote refreshes succeed.
2	Risk of locking out the validation account nsmith.	Bulk-removal commands can sweep too aggressively, including the lab's mandated nsmith local admin.	Every removal script and the Local Group GPO explicitly preserve Administrator and MOSA\nsmith. The allowlist is enforced positively (Add → Administrator, Add → MOSA\nsmith) rather than relying on negative pattern matching.
3	Inherited password policy in Group Policy Editor initially appeared compliant (length 10) but was not actually being enforced uniformly.	The Default Domain Policy values had not propagated to member hosts because gpupdate had not yet been pushed.	After editing the Default Domain Policy in GPME, gpupdate /force was run locally on dc1 (Figure 3.6.13) and a remote refresh attempted against every member.
4	Firewall rule for WinRM not present under the default group on a freshly imaged host.	Image variants ship with the WinRM service disabled and the firewall rules removed.	Used a safety-net New-NetFirewallRule for WINRM-HTTP-In-TCP (TCP 5985, all profiles) so the rule is recreated even if the predefined group is missing.
5	Disabling RDP from System Properties alone left the firewall rule group enabled — a re-enable by a local administrator would have immediately reopened TCP 3389.	Defence-in-depth gap: registry change protects the listener, the firewall rule protects the port.	Applied both fDenyTSConnections = 1 AND Disable-NetFirewallRule -DisplayGroup "Remote Desktop".

7. Recommendations & Future Improvements

The following enhancements are recommended to extend the hardening posture established in this lab:

7.1 Complete the Remaining Required Tasks

- Disable SMBv1 on every Windows host (`Set-SmbServerConfiguration -EnableSMB1Protocol $false; Disable-WindowsOptionalFeature -Online -FeatureName SMB1Protocol`; reboot if state shows `DisablePending`).
- Remove non-whitelisted software (FileZilla, TeamViewer, WinSCP) using `msiexec /x` or the vendor uninstaller via Group Policy Software Installation or PowerShell loop.
- Build the `\\fs1\MOSADocuments` share with the six required subfolders (Projects, Finances, Management, IT, HR, Contracts) and enable File and Printer Sharing.
- Configure IIS FTP on fs1 with three sites: PublicFTP (TCP 1234), InternalFTP (TCP 21), ClientFTP (TCP 6789), and add matching firewall rules.

7.2 Automation and Scaling

- Convert the per-host BEFORE/APPLY/AFTER blocks into a single Invoke-Command fan-out script that targets every host in `$hosts` via WinRM. This turns a multi-hour manual sweep into one PowerShell invocation.
- Move the local Administrators allowlist from a Group Policy Preference (which can be reverted by a local admin until the next refresh) to Restricted Groups under Computer Configuration → Policies → Windows Settings → Security Settings → Restricted Groups, which enforces membership at every refresh and is harder to subvert.
- Adopt Microsoft Local Administrator Password Solution (LAPS) so that the built-in Administrator account on each host has a unique, rotating, machine-stored password rather than a shared one.

7.3 Detection and Monitoring

- Forward Security, System and Sysmon event logs from every host to a central SIEM (e.g., Elastic via the already-whitelisted Winlogbeat agent) so that any future local-admin add, firewall rule change, or RDP re-enable is alerted on, not silently allowed.
- Enable PowerShell Module Logging and Script Block Logging (Computer Configuration → Administrative Templates → Windows Components → Windows PowerShell). Together with central log forwarding this gives high-fidelity visibility on what scripts are being executed where.
- Configure Windows Defender Attack Surface Reduction rules in audit mode initially, then in block mode, to cut off Office macro and credential-theft tradecraft used by ransomware operators.

7.4 Operational Maturity

- Document the entire hardening playbook (this report's Methodology section) as a runbook in the IT knowledge base, version-controlled, with the validation commands embedded so the next analyst can confirm compliance in minutes.

- Schedule a quarterly compliance sweep that re-runs the Section 4 PowerShell checks against every domain-joined host and emails the result to the security team.
- Define a formal change-management process for any addition to the local Administrators group: requests must go through the help desk, be approved by IT management, and (where genuinely needed) be granted via a time-bound group membership rather than an open-ended one.

8. References

- [1] Field Effect Software Inc., "S1P1 – Network Hardening: Network Diagram and Requirements," v1.1, Cyber Range Lab Documentation, 2024.
- [2] Microsoft Corporation, "Set-ADDefaultDomainPasswordPolicy," PowerShell ActiveDirectory Module Reference. [Online]. Available: <https://learn.microsoft.com/powershell/module/activedirectory/set-addefaultdomainpasswordpolicy>
- [3] Microsoft Corporation, "Account lockout policy," Windows Security Documentation. [Online]. Available: <https://learn.microsoft.com/windows/security/threat-protection/security-policy-settings/account-lockout-policy>
- [4] Microsoft Corporation, "Windows Defender Firewall with Advanced Security — PowerShell cmdlets," NetSecurity Module. [Online]. Available: <https://learn.microsoft.com/powershell/module/netsecurity/>
- [5] Microsoft Corporation, "about_Remote_Requirements," PowerShell Documentation. [Online]. Available: https://learn.microsoft.com/powershell/module/microsoft.powershell.core/about/about_remote_requirements
- [6] Microsoft Corporation, "Group Policy Preferences — Local Users and Groups," Group Policy Documentation. [Online]. Available: [https://learn.microsoft.com/previous-versions/windows/it-pro/windows-server-2008-R2-and-2008/cc731972\(v=ws.11\)](https://learn.microsoft.com/previous-versions/windows/it-pro/windows-server-2008-R2-and-2008/cc731972(v=ws.11))
- [7] Center for Internet Security, "CIS Microsoft Windows Server 2019 Benchmark v2.0.0," 2023.
- [8] National Institute of Standards and Technology, "Special Publication 800-53 Rev. 5 — Security and Privacy Controls for Information Systems and Organizations," 2020.
- [9] National Institute of Standards and Technology, "Special Publication 800-63B — Digital Identity Guidelines: Authentication and Lifecycle Management," 2020.
- [10] Microsoft Security Response Center, "Stop using SMB1," blog post, 16 Sep 2016. [Online]. Available: <https://techcommunity.microsoft.com/t5/storage-at-microsoft/stop-using-smb1/ba-p/425858>

9. Appendices

Appendix A — Domain Credentials (Lab Use Only)

The following credentials are provided by Field Effect for laboratory use only and must never appear in a production handover document.

User	sAMAccountName	Role	Password
Kyle Neys	kneys	Domain Admin	4ResetNow!
Jane South	jsouth	Domain Admin	5ResetNow!
Mary Powel	mpowel	Domain Admin	6ResetNow!
Nicolas Smith	nsmith	Normal — DO NOT MODIFY (validation)	7ResetNow!
Marta Jones	mjones	Normal User	8ResetNow!
Clint Cage	ccage	Normal User	9ResetNow!
Alice Wilson	awilson	Normal User	4ResetNow!
James Grey	jgrey	Normal User	3ResetNow!
Robert Austin	raustin	Normal User	2ResetNow!
Jane Marty	jmarty	Normal User	1ResetNow!
Todd Green	tgreen	Normal User	0ResetNow!
Cindy Tucker	ctucker	Normal User	11ResetNow!
Brenda Harris	bharris	Normal User	12ResetNow!

Appendix B — Validation Command Reference

```
# --- Domain-scope (run on dc1) ---
Import-Module ActiveDirectory
Get-ADDefaultDomainPasswordPolicy |
    Select MinPasswordLength, PasswordHistoryCount, MaxPasswordAge,
        LockoutThreshold, LockoutDuration, ComplexityEnabled
Search-ADAccount -AccountExpired -UsersOnly

# --- Per-host (run on each Windows target) ---
Get-NetFirewallProfile | Select Name, Enabled
Get-NetFirewallRule -DisplayGroup "Windows Remote Management" |
    Select DisplayName, Enabled
(Get-ItemProperty 'HKLM:\System\CurrentControlSet\Control\Terminal
Server').fDenyTSConnections
Get-NetFirewallRule -DisplayGroup "Remote Desktop" | Select DisplayName, Enabled
Get-Service WinRM
Test-WSMan -ComputerName localhost
Get-LocalGroupMember -Group "Administrators" |
    Select Name, ObjectClass, PrincipalSource
```

Appendix C — Flag Validation Log

Flag	Description	Status	Validation Path
Flag 9	Harden the network (composite gate covering	Cleared	Field Effect WinRM probes + manual

	Tasks 1-5).		PowerShell sweep
--	-------------	--	------------------

End of report.